

Reporte de cumplimiento de políticas de seguridad

acme-payments

Identificador del reporte	0f8f7c1e-4c1a-4f3e-9d7a-2b6c1d0e9a11
Estado	Generado
Repositorio	acme-payments
Origen	Git: https://ci-bot:*****@github.com/acme/payments.git (rama main)
Análisis	85db2d64-9c6f-4dd2-8eb0-254ab3496a8d
Ejecución del análisis	2026-09-28 01:16:35 COT – 2026-09-28 01:17:17 COT
Reglas ejecutadas	24 de 24
Generado por	auditor
Fecha de generación	2026-09-28 01:21:35 COT
Checksum SHA-256	9f2c4e1b7a3d5f60c8e9b1a2d3c4e5f60718293a4b5c6d7e8f90a1b2c3d4e5f6

Documento confidencial

Este reporte contiene resultados de seguridad del repositorio analizado y está dirigido a responsables de seguridad, auditoría y dirección. Los secretos detectados se muestran enmascarados (*****). La integridad del contenido puede verificarse con el checksum SHA-256 impreso en el pie de cada página.

Índice

1. Resumen ejecutivo.....

3

2. Cobertura por categoría.....

3

3. Resultados por política.....

4

4. Hallazgos detallados.....

5

Cada página incluye su número y el checksum SHA-256 del reporte. Si el checksum no coincide con el registrado en SegSoft, el documento no debe considerarse evidencia válida.

1. Resumen ejecutivo

El análisis del repositorio «acme-payments» evaluó 5 políticas de seguridad mediante 24 reglas. Del total, 3 cumplen, 1 no cumple y 1 requiere revisión, para un cumplimiento de 60 % (55,5 % ponderado por criticidad). Se identificaron 5 hallazgos, 2 de severidad alta o crítica. Durante la ejecución se registró 1 error de regla; los resultados de las políticas afectadas pueden estar incompletos.

60 % Cumplimiento de políticas	55,5 % Cumplimiento ponderado	5 Políticas evaluadas	5 Hallazgos
--	---	---	-----------------------------------

Hallazgos por severidad

Crítica	Alta	Media	Baja
1	1	2	1

Estado de las políticas

No cumple	Requiere revisión	Cumple
1	1	3

2. Cobertura por categoría

Distribución de las políticas evaluadas y de los hallazgos en las cinco categorías del catálogo de SegSoft. Una categoría sin políticas evaluadas no tiene cobertura en este análisis.

Categoría	Políticas	Cumplen	No cumplen	Revisión	Hallazgos	Altos / críticos	Cumplimiento
Inyección SQL	2	1	1	0	2	1	50 %
Cross-Site Scripting (XSS)	1	1	0	0	1	0	100 %
Fallas de autenticación	2	1	0	1	2	1	50 %
Manejo inseguro de datos	0	0	0	0	0	0	Sin cobertura
Dependencias vulnerables	0	0	0	0	0	0	Sin cobertura

3. Resultados por política

Resultado de cada política seleccionada, primero las que no cumplen. El peso indica la criticidad de la política en el cumplimiento ponderado.

Política	Categoría	Marco / control	Peso	Estado	Hallazgos	Altos / críticos
Consultas parametrizadas obligatorias	Inyección SQL	OWASP Top 10 2021 · A03:2021	50	No cumple	2	1
Gestión segura de credenciales de autenticación	Fallas de autenticación	OWASP Top 10 2021 · A03:2021	50	Requiere revisión	2	1
Content Security Policy obligatoria	Cross-Site Scripting (XSS)	OWASP Top 10 2021 · A03:2021	50	Cumple	1	1
Tokens JWT con expiración y rotación	Fallas de autenticación	OWASP Top 10 2021 · A03:2021	50	Cumple	0	0
Validación de entradas antes de construir consultas SQL	Inyección SQL	OWASP Top 10 2021 · A03:2021	50	Cumple	0	0

4. Hallazgos detallados

5 hallazgos ordenados por severidad, de crítica a baja. Los fragmentos de evidencia se muestran con los secretos enmascarados.

Severidad crítica (1)

#1 **CRÍTICA** Política SQL_INJECTION

Categoría: Inyección SQL · CWE-89

Ubicación: src/db/UserDao.java:42

```
String q = "SELECT * FROM users WHERE id=" + id; // api_key=*****
```

Acción sugerida: Mover el secreto a un gestor de secretos y rotarlo.

Severidad alta (1)

#2 **ALTA** Política SQL_INJECTION

Categoría: Inyección SQL · CWE-89

Ubicación: src/db/OrderDao.java:88

```
headers.put("Authorization", "Bearer *****");
```

Acción sugerida: Mover el secreto a un gestor de secretos y rotarlo.

Severidad media (2)

#3 **MEDIA** Política AUTHENTICATION_FAILURE

Categoría: Fallas de autenticación · CWE-89

Ubicación: config/app.yml:7

```
aws:
  access_id: *****
  password: "*****"
```

Acción sugerida: Mover el secreto a un gestor de secretos y rotarlo.

#4 **MEDIA** Política AUTHENTICATION_FAILURE

Categoría: Fallas de autenticación · CWE-89

Ubicación: keys/deploy.pem:1

```
-----BEGIN RSA PRIVATE KEY-----*****-----END RSA PRIVATE KEY-----
db_password=*****
```

Acción sugerida: Mover el secreto a un gestor de secretos y rotarlo.

Severidad baja (1)

#5 **BAJA** Política XSS

Categoría: Cross-Site Scripting (XSS) · CWE-89

Ubicación: src/web/banner.js:3

```
const apiKey = "*****";
```

Acción sugerida: Mover el secreto a un gestor de secretos y rotarlo.